SCRUM-13 — Analyse de sécurité de TicketPulse

La sécurité constitue une exigence essentielle de TicketPulse en raison de la nature des opérations réalisées par la plateforme. Le système traite des achats de billets, des réservations de sièges et des informations associées aux utilisateurs. Une défaillance de sécurité pourrait compromettre les données, perturber une vente ou permettre des opérations frauduleuses.

La sécurité doit également être considérée en parallèle de la disponibilité et de la performance. TicketPulse pouvant atteindre jusqu'à **250 000 utilisateurs simultanés et 50 000 requêtes par seconde**, les mécanismes de protection doivent rester efficaces lors des ventes flash.

L'objectif de cette analyse est donc d'identifier les principales menaces susceptibles d'affecter TicketPulse et de proposer des contrôles permettant de réduire les risques.

1. Objectifs de sécurité

Pour TicketPulse, nous retenons quatre objectifs principaux.

Confidentialité : empêcher l'accès non autorisé aux renseignements des utilisateurs et aux informations sensibles liées aux transactions.

Intégrité : empêcher la modification non autorisée des réservations, billets, transactions et autres données du système.

Disponibilité : maintenir TicketPulse accessible aux utilisateurs légitimes, notamment pendant les ventes flash.

Traçabilité : conserver suffisamment d'informations sur les opérations importantes afin de pouvoir détecter et analyser les comportements anormaux ou incidents.

La disponibilité est particulièrement importante puisque l'énoncé impose explicitement une **disponibilité élevée durant les ventes flash**.

2. Identification des principales menaces

ID	Menace	Élément concerné	Risque
M01	Accès non autorisé à un compte	Comptes utilisateurs	Un attaquant accède au compte d'un autre utilisateur et réalise des opérations sans autorisation.
M02	Vol ou interception de données	Communications client-serveur	Des informations sensibles peuvent être interceptées pendant leur transmission.
M03	Fraude ou manipulation du paiement	Processus de paiement	Une transaction peut être falsifiée, répétée ou manipulée.
M04	Double réservation / double achat	Système de réservation	Deux utilisateurs peuvent tenter d'obtenir simultanément le même siège.
M05	Attaque par déni de service	Infrastructure TicketPulse	Un volume important de requêtes malveillantes peut rendre la plateforme indisponible.
M06	Injection de données malveillantes	Formulaires / API / base de données	Des entrées malveillantes peuvent provoquer des opérations non prévues sur le système.
M07	Modification non autorisée d'un billet	Billet électronique / QR Code	Un billet ou son QR Code pourrait être falsifié ou modifié.
M08	Abus des mécanismes de réservation	Réservation temporaire	Des utilisateurs automatisés peuvent réserver massivement des sièges afin d'empêcher les clients légitimes d'y accéder.
M09	Accès excessif par un utilisateur interne	Administration	Un compte disposant de privilèges trop importants pourrait consulter ou modifier des informations qui ne lui sont pas nécessaires.
M10	Exposition d'informations dans les journaux	Logs	Des informations sensibles pourraient être enregistrées accidentellement dans les journaux du système.

3. Contrôles de sécurité proposés

Pour chacune de ces menaces, TicketPulse doit prévoir un ou plusieurs mécanismes de protection.

ID	Menace	Contrôle proposé	Objectif
M01	Accès non autorisé	Authentification robuste, gestion sécurisée des sessions et limitation des tentatives de connexion.	Réduire les risques de compromission des comptes.
M02	Interception des données	Chiffrement des communications avec HTTPS/TLS.	Protéger les informations pendant leur transmission.
M03	Fraude au paiement	Utilisation d'un prestataire de paiement sécurisé et validation côté serveur du résultat de la transaction.	Empêcher la falsification des paiements.
M04	Double réservation	Verrouillage ou mécanisme transactionnel atomique lors de la réservation d'un siège.	Garantir qu'un seul utilisateur puisse obtenir un siège.
M05	Déni de service	Rate limiting, répartition de charge et mécanismes de filtrage du trafic.	Préserver la disponibilité pendant une attaque ou un trafic anormal.
M06	Injection	Validation et assainissement des entrées ainsi que requêtes paramétrées.	Empêcher l'exécution d'entrées malveillantes.
M07	Falsification du billet	Identifiant unique et validation du QR Code côté serveur.	Vérifier l'authenticité du billet.
M08	Réservations abusives	Limitation du nombre de réservations et de requêtes par utilisateur/session et expiration automatique des réservations.	Empêcher le blocage artificiel des sièges.
M09	Privilèges excessifs	Contrôle d'accès basé sur les rôles et principe du moindre privilège.	Limiter chaque utilisateur aux opérations nécessaires à son rôle.

M10	Données sensibles dans les logs	Masquage des données sensibles et contrôle de l'accès aux journaux.	Éviter l'exposition accidentelle d'informations confidentielles.

4. Sécurisation du paiement

Le paiement représente l'une des opérations les plus sensibles de TicketPulse puisque l'énoncé exige explicitement un **paiement sécurisé**.

Dans notre conception, nous proposons de confier le traitement des données de paiement à un **prestataire spécialisé** plutôt que de stocker directement les informations de carte bancaire dans TicketPulse. Cette décision constitue une **proposition architecturale de notre équipe**, car le sujet ne précise pas la technologie de paiement utilisée.

TicketPulse devra principalement recevoir et vérifier le résultat de la transaction avant de confirmer définitivement l'achat. Une transaction refusée ou interrompue ne doit jamais provoquer la génération définitive d'un billet.

5. Protection du système de réservation

La réservation constitue une deuxième zone particulièrement critique. L'énoncé impose qu'un même siège **ne puisse jamais être vendu deux fois**, prévoit une réservation temporaire pendant l'achat et demande une protection contre les accès concurrents et les doubles achats.

Le système devra donc traiter la réservation d'un siège comme une opération atomique : lorsque deux utilisateurs tentent de réserver simultanément le même siège, une seule opération doit réussir.

La réservation temporaire doit également posséder une expiration. Si l'utilisateur abandonne son achat ou ne termine pas son paiement dans le délai prévu, le siège doit être libéré.

6. Protection contre les abus pendant les ventes flash

La charge exceptionnelle de TicketPulse crée également un risque de sécurité. Pendant une vente populaire, le système peut recevoir jusqu'à **50 000 requêtes par seconde**.

Il faut donc pouvoir distinguer autant que possible le trafic légitime des comportements abusifs.

Nous proposons notamment :

- une limitation du nombre de requêtes (*rate limiting*) ;

- une limitation du nombre de réservations actives par utilisateur ;
- la détection des volumes anormalement élevés de requêtes ;
- l'expiration automatique des réservations abandonnées ;
- une surveillance des erreurs et comportements inhabituels.

7. Matrice synthétique des risques

Pour rendre ton analyse plus professionnelle, nous pouvons également classer les risques :

Menace	Probabilité	Impact	Niveau de risque	Priorité
Compromission d'un compte	Moyenne	Élevé	Élevé	Haute
Interception de données	Faible à moyenne	Élevé	Élevé	Haute
Fraude au paiement	Moyenne	Très élevé	Critique	Très haute
Double achat d'un siège	Élevée	Très élevé	Critique	Très haute
Déni de service	Moyenne à élevée	Très élevé	Critique	Très haute
Injection	Moyenne	Élevé	Élevé	Haute
Falsification d'un billet	Moyenne	Élevé	Élevé	Haute
Réservations automatisées abusives	Élevée lors d'une vente populaire	Élevé	Élevé	Haute
Privilèges excessifs	Faible à moyenne	Élevé	Moyen/élevé	Moyenne
Exposition de données dans les logs	Moyenne	Moyen à élevé	Moyen	Moyenne

*

Attention : les niveaux de probabilité et de risque de ce tableau sont **nos estimations de conception**. Ils ne sont pas fournis par le professeur dans l'énoncé.

Conclusion

L'analyse de sécurité de TicketPulse met en évidence plusieurs risques importants liés principalement aux comptes utilisateurs, au paiement, à la réservation des sièges, à la protection des données et à la disponibilité de la plateforme.

Les risques associés au **paiement, aux doubles achats et à l'indisponibilité pendant les ventes flash** doivent recevoir une priorité élevée en raison de leurs conséquences potentielles sur les utilisateurs et l'entreprise.

La stratégie proposée repose notamment sur le chiffrement des communications, la validation des entrées, le contrôle des accès, la sécurisation du paiement, la gestion atomique des réservations, la limitation des requêtes et la surveillance des comportements anormaux. Ces contrôles devront être complétés par une stratégie d’observabilité permettant de détecter rapidement les incidents.